

Penetration Testing Techniques

Introduction

Penetration testing is an authorized security assessment where testers simulate real-world attacks to identify and validate vulnerabilities.

Unlike scanners, penetration testers think like attackers. They combine tools, manual testing, logic flaws, and chaining weaknesses.

Objectives:

- Identify exploitable weaknesses
 - Measure real-world risk
 - Test security controls
 - Improve defenses through recommendations
-

Types of Penetration Testing

Black Box Testing

Tester has no internal knowledge.

Simulates an external attacker.

White Box Testing

Tester has full knowledge such as source code, architecture, credentials.

Provides deeper assessment.

Gray Box Testing

Tester has partial information.

Common in modern engagements.

Main Phases of Penetration Testing

1. Pre-Engagement and Scope

Before testing begins:

- Written authorization
- Rules of engagement
- Allowed targets
- Testing hours
- Communication channels

This is legally and operationally critical.

2. Reconnaissance

Information gathering about the target.

Passive Recon:

- WHOIS lookup
- DNS records
- Public documents
- Search engines

Active Recon:

- Port scanning
- Service enumeration

Tools:

- Shodan
 - Maltego
 - theHarvester
-

3. Scanning and Enumeration

Discover services and versions.

Examples:

- SSH on port 22

- HTTP on port 80
- SMB on port 445

Also identifies usernames, shares, directories, banners, and software versions.

Tools:

- Nmap
 - Gobuster
-

4. Exploitation

Using weaknesses to gain access.

Examples:

- SQL injection login bypass
- Weak admin password
- Remote code execution flaw
- Misconfigured file upload

Tools:

- Metasploit Framework
 - Burp Suite
-

5. Post Exploitation

After initial access, testers check potential impact.

Activities:

- Privilege escalation
- Credential access
- Internal movement
- Sensitive data exposure
- Persistence testing

6. Reporting

One of the most important phases.

A professional report includes:

- Executive summary
- Scope
- Methodology
- Findings
- Severity ratings
- Screenshots
- Proof of concept
- Remediation steps

Common Methodologies

PTES

Penetration Testing Execution Standard:

- Pre-engagement
- Intelligence gathering
- Threat modeling
- Exploitation
- Post exploitation
- Reporting

OWASP WSTG

Web Security Testing Guide for web apps.

Ethics and Legal Importance

Penetration testing without permission may be illegal. Always require written authorization.

Real-Life Case Study – Internal Network Pentest

A company requested internal assessment. Findings:

- Shared folders accessible to everyone
- Default printer admin password
- Weak local admin credentials

Impact:

Sensitive HR files could be accessed.

Lesson:

Internal threats matter as much as external threats.

Real-Life Case Study – Web Application Test

During testing, password reset tokens were predictable.

Impact:

Any user account could be taken over.

Lesson:

Business logic flaws are often missed by automated scanners.